

Document de conception initiale du projet SIEM Cloud-Native basé sur Azure Monitor et Microsoft Sentinel

Wala Hassine - Smartovate LTD

11 juin 2026

1 Présentation générale du projet

1.1 Contexte du projet

L'adoption croissante des architectures cloud a approfondi la surface d'attaque de l'entreprise. Les modèles de sécurité périmétrique traditionnels ne couvrent plus les menaces avancées propres aux environnements cloud.

SMARTOVATE LTD initie la mise en place d'un SIEM cloud-native reposant sur les services natifs Microsoft Azure : Azure Monitor pour la collecte des logs et métriques, et Microsoft Sentinel en tant que SIEM et SOAR.

Le projet est conduit dans un environnement de test (bac à sable Azure) sur une durée de deux mois (juin-juillet 2026).

1.2 Enjeux et problématique

Les équipes SOC ne disposent pas d'une infrastructure centralisée de supervision. Cette absence génère trois dysfonctionnements critiques :

- Absence de visibilité consolidée sur la posture de sécurité de l'environnement Azure.
- Détection tardive des menaces avancées : connexions depuis des IP malveillantes, élévations de privilèges non autorisées dans Azure AD.
- Charge opérationnelle élevée liée au traitement manuel des incidents de sécurité.

Problématique centrale : Comment concevoir et déployer une infrastructure de surveillance centralisée capable de détecter les anomalies en temps réel, de visualiser la posture de sécurité via des tableaux de bord, et d'automatiser la réponse aux incidents récurrents ?
--

1.3 Objectifs du projet

Le projet doit atteindre les cinq objectifs suivants dans un délai de deux mois :

ID	Description
OBJ-01	Déployer et configurer un espace de travail Log Analytics pour centraliser les journaux d'événements.
OBJ-02	Connecter les sources de données Azure natives (Azure AD, Office 365, VMs, pare-feux) à Azure Sentinel.
OBJ-03	Créer des Analytics Rules générant des alertes basées sur des scénarios de menaces identifiés.
OBJ-04	Développer des Workbooks interactifs pour la visualisation de la posture de sécurité.
OBJ-05	Concevoir et implémenter des Playbooks SOAR via Azure Logic Apps pour automatiser la réponse aux incidents.

2 Analyse du besoin

2.1 Synthèse des exigences

Le système doit couvrir trois domaines fonctionnels :

Domaine	Description
Collecte et centralisation	L'ensemble des logs produits par l'environnement Azure (Azure AD, activité Azure, VMs, pare-feux) doit être agrégé dans un espace de travail Log Analytics unique. La rétention est fixée à 30 jours pour l'environnement de test.
Détection des menaces	Le système doit identifier automatiquement les comportements anormaux via des règles KQL. Les scénarios couverts sont : connexions depuis des IP malveillantes connues, connexions depuis des pays inhabituels, et élévations de privilèges non autorisées dans Azure AD.
Automatisation de la réponse	En cas d'incident de sévérité haute, le système doit déclencher automatiquement un Playbook SOAR : notification sur Microsoft Teams et désactivation d'un compte Azure AD compromis via l'API Microsoft Graph.

2.2 Définition du périmètre

Inclus dans le périmètre :

- Configuration d’Azure Monitor et du Log Analytics Workspace.
- Activation d’Azure Sentinel et intégration des connecteurs de données natifs Microsoft.
- Création de 5 à 10 règles de détection personnalisées en KQL.
- Création de 2 Workbooks : vue d’ensemble sécurité et analyse des identités.
- Développement de 2 Playbooks SOAR : notification Teams/Email et blocage de compte Azure AD.
- Documentation technique et guide d’exploitation.

Exclus du périmètre :

- Intégration de sources on-premise nécessitant des agents non standards.
- Développement de connecteurs personnalisés via API REST pour des solutions tierces non supportées nativement.
- Gestion de la facturation et optimisation avancée des coûts.
- Réponse aux incidents réels en environnement de production.

2.3 Parties prenantes et acteurs

Acteur	Rôle
Administrateur sécurité	Déploiement et configuration de l’infrastructure Azure Sentinel.
Analyste SOC	Traitement quotidien des incidents, déclenchement des Playbooks.
Responsable sécurité	Consultation des Workbooks pour évaluation de la posture de sécurité.
Azure Sentinel	Moteur SIEM : analyse, corrélation d’événements, gestion des incidents.
Azure Logic Apps	Orchestrateur des Playbooks SOAR.

3 Spécifications fonctionnelles

3.1 Exigences fonctionnelles

EF-01 — Centralisation des journaux d'événements

Identifiant	EF-01
Intitulé	Création et configuration de l'espace de travail Log Analytics
Priorité	Must Have
Source	US 1.1 — Epic 1
Acteurs	Administrateur sécurité
Dépendances	Aucune — exigence fondatrice.

Description

Le système doit disposer d'un espace de travail Log Analytics unique, déployé dans la région Azure appropriée, servant de point de collecte et de stockage centralisé pour l'ensemble des journaux d'événements de l'environnement Azure.

Critères d'acceptation

- L'espace de travail est créé dans la région Azure correcte et accessible.
- La rétention des données est configurée à 30 jours.
- Les permissions RBAC sont définies et restreintes à l'équipe de sécurité.
- Les logs sont interrogeables via des requêtes KQL basiques sans erreur.

EF-02 — Connexion des sources de données natives Microsoft

Identifiant	EF-02
Intitulé	Activation de Microsoft Sentinel et intégration des connecteurs de données
Priorité	Must Have
Source	US 1.2 — Epic 1
Acteurs	Analyste SOC, Administrateur sécurité
Dépendances	EF-01.

Description

Microsoft Sentinel doit être activé sur l'espace de travail Log Analytics. Les connecteurs de données natifs Microsoft doivent être configurés pour ingérer les événements de sécurité issus d'Azure Active Directory (Entra ID), du journal d'activité Azure, des Pare-feux Azure, des Machines virtuelles Azure et d'Office 365.

Critères d'acceptation

- Microsoft Sentinel est activé et opérationnel sur l'espace de travail.
- Le connecteur Azure Active Directory est configuré et fonctionnel.
- Le connecteur Azure Activity est configuré et fonctionnel.
- Le connecteur Pare-feux Azure est configuré et fonctionnel.
- Le connecteur Machines virtuelles Azure est configuré et fonctionnel.
- Le connecteur Office 365 est configuré et fonctionnel.
- Les logs ingérés sont visibles et interrogeables via des requêtes KQL basiques.

EF-03 — Détection des connexions depuis des sources malveillantes

Identifiant	EF-03
Intitulé	Règle d'analyse — Connexions suspectes par IP malveillante ou géolocalisation anormale
Priorité	Must Have
Source	US 2.1 — Epic 2
Acteurs	Analyste SOC
Dépendances	EF-01, EF-02.

Description

Le système doit détecter automatiquement les connexions réussies provenant d'adresses IP référencées dans la Threat Intelligence Sentinel ou issues de pays inhabituels pour l'organisation, afin d'identifier les compromissions de comptes.

Critères d'acceptation

- La requête KQL exploite la Threat Intelligence intégrée à Sentinel pour l'identification des IP malveillantes.
- La règle d'analyse est planifiée avec une fréquence d'exécution d'une heure maximum.
- Tout déclenchement génère un incident dans Microsoft Sentinel.
- Le mapping des entités (Account, IP) est correctement configuré dans l'alerte.

EF-04 — Détection des élévations de privilèges non autorisées

Identifiant	EF-04
Intitulé	Règle d'analyse — Ajout d'un utilisateur à un rôle d'administrateur global
Priorité	Must Have
Source	US 2.2 — Epic 2
Acteurs	Analyste SOC
Dépendances	EF-01, EF-02.

Description

Le système doit surveiller en continu les logs d'audit Azure AD afin de détecter tout ajout d'un utilisateur à un rôle d'administrateur global ou à un rôle sensible, et générer un incident de sévérité haute en conséquence.

Critères d'acceptation

- La requête KQL surveille la table d'audit Azure AD (AuditLogs) et cible les opérations d'ajout de rôle sensible.
- L'incident généré porte la sévérité Haute.
- Le mapping des entités (Account, IP) est correctement renseigné dans la définition de l'alerte.
- L'incident est visible dans la file d'incidents Sentinel.

EF-05 — Visualisation de la posture de sécurité des identités

Identifiant	EF-05
Intitulé	Workbook — Tableau de bord de la posture d'identité
Priorité	Must Have
Source	US 3.1 — Epic 3
Acteurs	Responsable sécurité, Analyste SOC
Dépendances	EF-01, EF-02.

Description

Le système doit fournir un Workbook interactif permettant au responsable sécurité d'évaluer rapidement l'état de la sécurité des identités à partir des données d'authentification ingérées dans Log Analytics.

Critères d'acceptation

- Le Workbook affiche un graphique des connexions échouées, segmenté par raison d'échec.
- Une carte géographique représente l'origine des connexions entrantes.
- Des filtres temporels interactifs sont disponibles (plages : 24h, 7 jours).
- Le Workbook est accessible depuis le portail Microsoft Sentinel sans droits d'administration.

EF-06 — Notification automatique des incidents de sévérité haute

Identifiant	EF-06
Intitulé	Playbook SOAR — Notification d'incident sur Microsoft Teams
Priorité	Must Have
Source	US 4.1 — Epic 4
Acteurs	Analyste SOC
Dépendances	EF-03, EF-04.

Description

Le système doit déclencher automatiquement une notification sur un canal Microsoft Teams dédié dès la création d'un incident de sévérité haute dans Sentinel, afin de réduire le délai de prise en charge par l'équipe SOC.

Critères d'acceptation

- Une Logic App est créée avec le déclencheur Azure Sentinel Incident.
- Le Playbook extrait les métadonnées de l'incident : titre, sévérité, lien direct.
- Un message formaté (Adaptive Card) est posté dans le canal Teams désigné.
- Une Automation Rule lie ce Playbook à tous les incidents de sévérité Haute.
- L'exécution du Playbook est journalisée dans les logs de la Logic App.

EF-07 — Remédiation automatisée par désactivation de compte compromis

Identifiant	EF-07
Intitulé	Playbook SOAR — Désactivation d'un compte Azure AD compromis
Priorité	Should Have
Source	US 4.2 — Epic 4
Acteurs	Analyste SOC
Dépendances	EF-02, EF-06.

Description

Le système doit permettre à un analyste SOC de déclencher manuellement un Playbook de remédiation afin de désactiver un compte Azure AD compromis, révoquer ses sessions actives, et tracer l'action dans l'incident Sentinel associé.

Critères d'acceptation

- Le Playbook utilise le déclencheur Azure Sentinel Alert ou Incident.
- Il interagit avec l'API Microsoft Graph (ou le connecteur Azure AD natif) pour révoquer les sessions et désactiver le compte.
- Un commentaire automatique est ajouté dans l'incident Sentinel confirmant l'action exécutée (compte ciblé, horodatage, résultat).
- L'identité managée (Managed Identity) de la Logic App dispose de la permission User.ReadWrite.All.

3.2 Exigences non fonctionnelles

ENF-01 — Performance : gestion du délai d'ingestion

Identifiant	ENF-01
Catégorie	Performance
Priorité	Must Have

Description

Les règles d'analyse KQL doivent compenser le délai d'ingestion natif des logs Azure AD (jusqu'à 15–30 minutes) en utilisant la fonction `ingestion_time()` comme référence temporelle dans la fenêtre de recherche (lookback period), et non `TimeGenerated`.

Critère de vérification

- Aucune alerte ne doit être manquée en raison d'un décalage temporel entre l'émission de l'événement et son ingestion dans Log Analytics.

ENF-02 — Sécurité : principe du moindre privilège

Identifiant	ENF-02
Catégorie	Sécurité
Priorité	Must Have
Référence ISO 27001	A.9.4 — Contrôle d'accès aux systèmes et aux applications

Description

Les permissions RBAC sur l'espace de travail Log Analytics et les droits accordés aux identités managées des Logic Apps doivent respecter le principe du moindre privilège. Toute élévation de droit doit être documentée et justifiée.

Critère de vérification

- Audit des permissions RBAC effectué et validé avant la mise en service.

ENF-03 — Fiabilité : réduction des faux positifs

Identifiant	ENF-03
Catégorie	Fiabilité
Priorité	Should Have

Description

Des Watchlists Sentinel doivent être implémentées pour exclure des règles de détection les adresses IP et comptes de service légitimes et approuvés, afin de maintenir un taux de faux positifs acceptable et de ne pas saturer la file d'incidents SOC.

Critère de vérification

- Taux de faux positifs évalué et jugé acceptable lors des tests d'intégration en semaine 5-6.

ENF-04 — Traçabilité et auditabilité

Identifiant	ENF-04
Catégorie	Traçabilité
Priorité	Must Have
Référence ISO 27001	A.12.4 — Journalisation et surveillance / A.16.1 — Gestion des incidents

Description

Toute action automatisée ou manuelle exécutée par un Playbook SOAR (désactivation de compte, notification) doit être tracée par un commentaire horodaté dans l'incident Sentinel correspondant, garantissant la traçabilité complète du cycle de vie de l'incident.

Critère de vérification

- Chaque incident clôturé contient au minimum un commentaire de traçabilité généré par le Playbook.

3.3 Contraintes technique

ID	Description
C-01	Le projet est intégralement réalisé dans un environnement de test Azure (sandbox) , toute action sur un environnement de production est exclue du périmètre.
C-02	Seuls les connecteurs de données natifs Microsoft sont utilisés. Le développement de connecteurs personnalisés via API REST est hors périmètre.
C-03	La durée d'exécution du projet est limitée à 8 semaines, avec des jalons hebdomadaires définis dans le planning prévisionnel.

4 Modélisation du système

4.1 Diagrammes de cas d'utilisation

UCd-01 — Use Case — Epic 1 : Infrastructure & Collecte

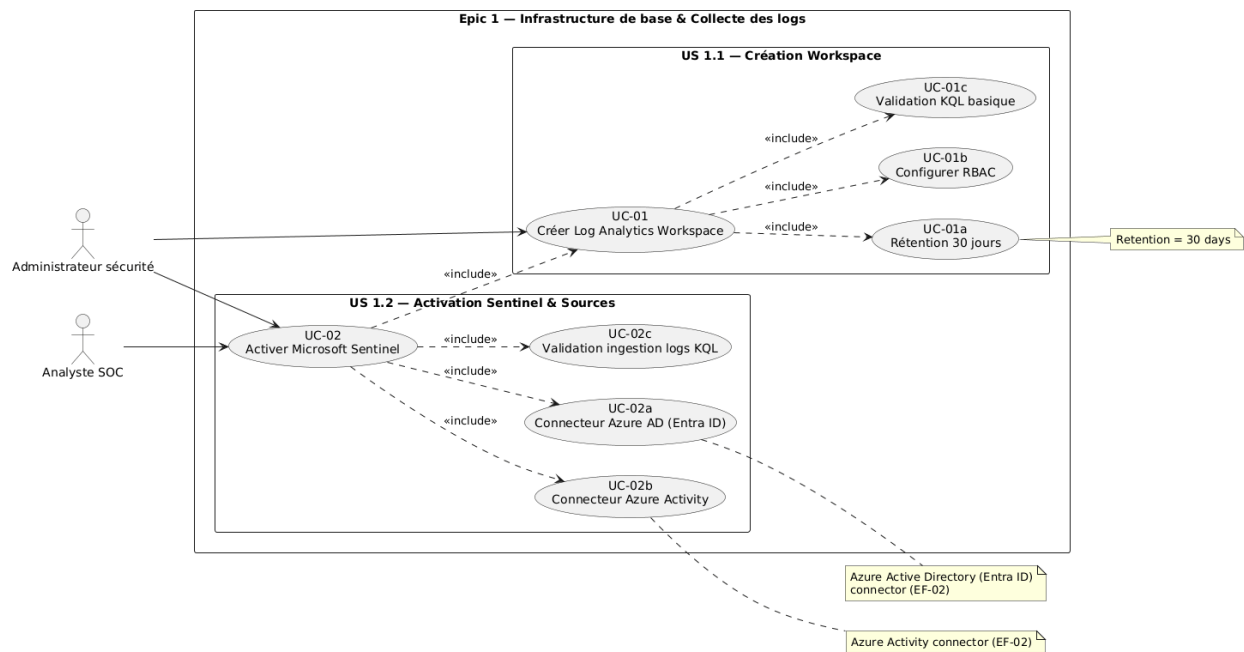


FIGURE 1 — UCd-01 — Use Case — Epic 1 : Infrastructure & Collecte

UCd-02 — Use Case — Epic 2 : Détection SIEM

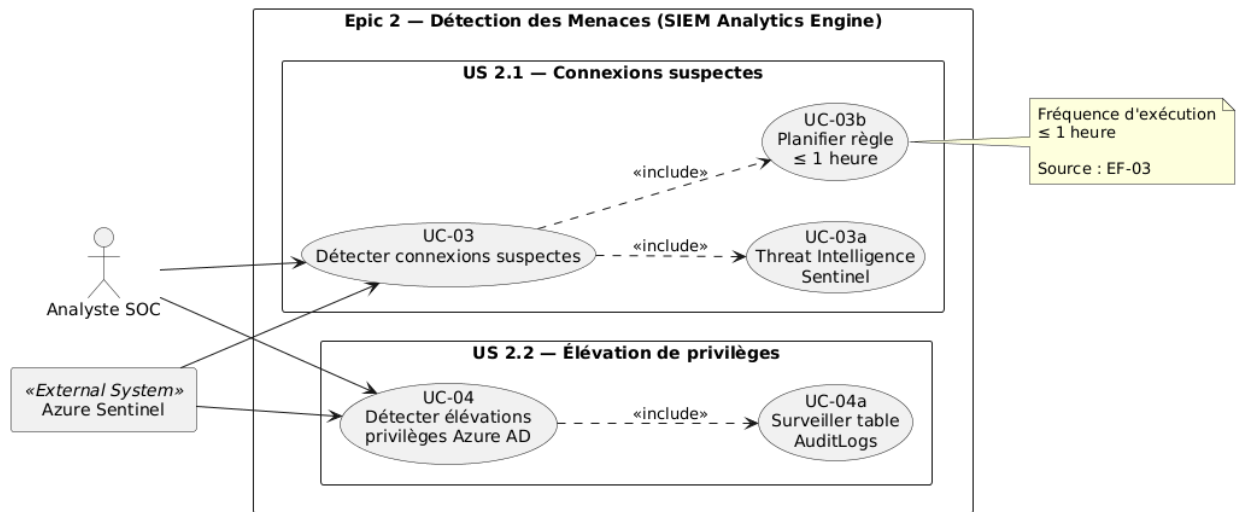


FIGURE 2 – UCd-02 — Use Case — Epic 2 : Détection SIEM

UCd-03 — Use Case — Epic 3 : Visualisation Workbooks

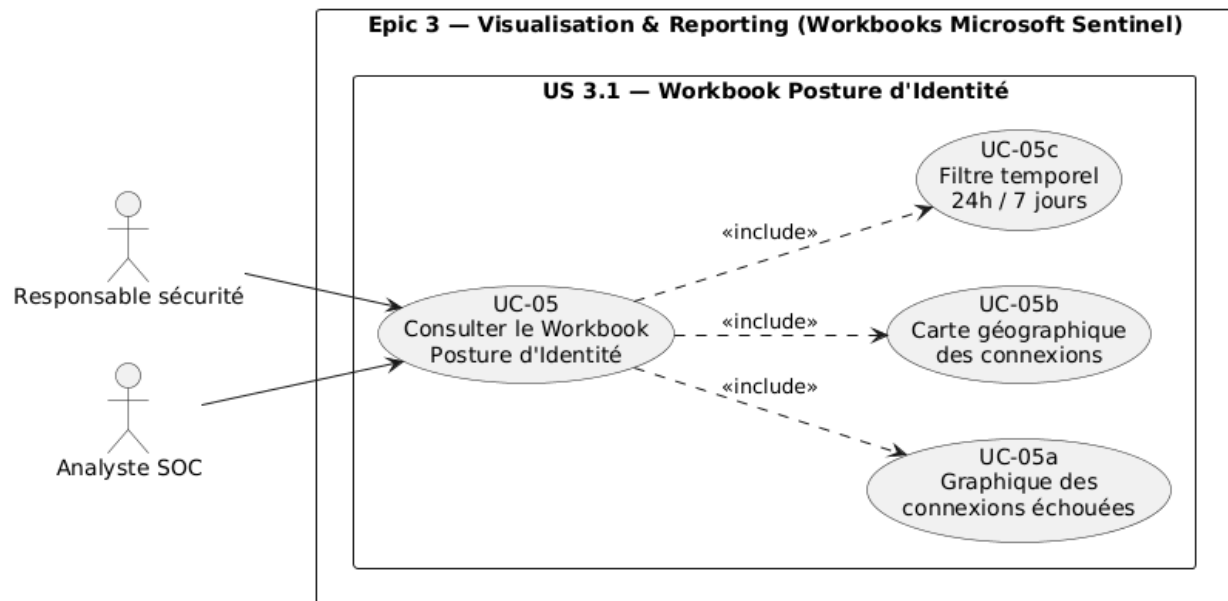


FIGURE 3 – UCd-03 — Use Case — Epic 3 : Visualisation Workbooks

UCd-04 — Use Case — Epic 4 : Automatisation SOAR

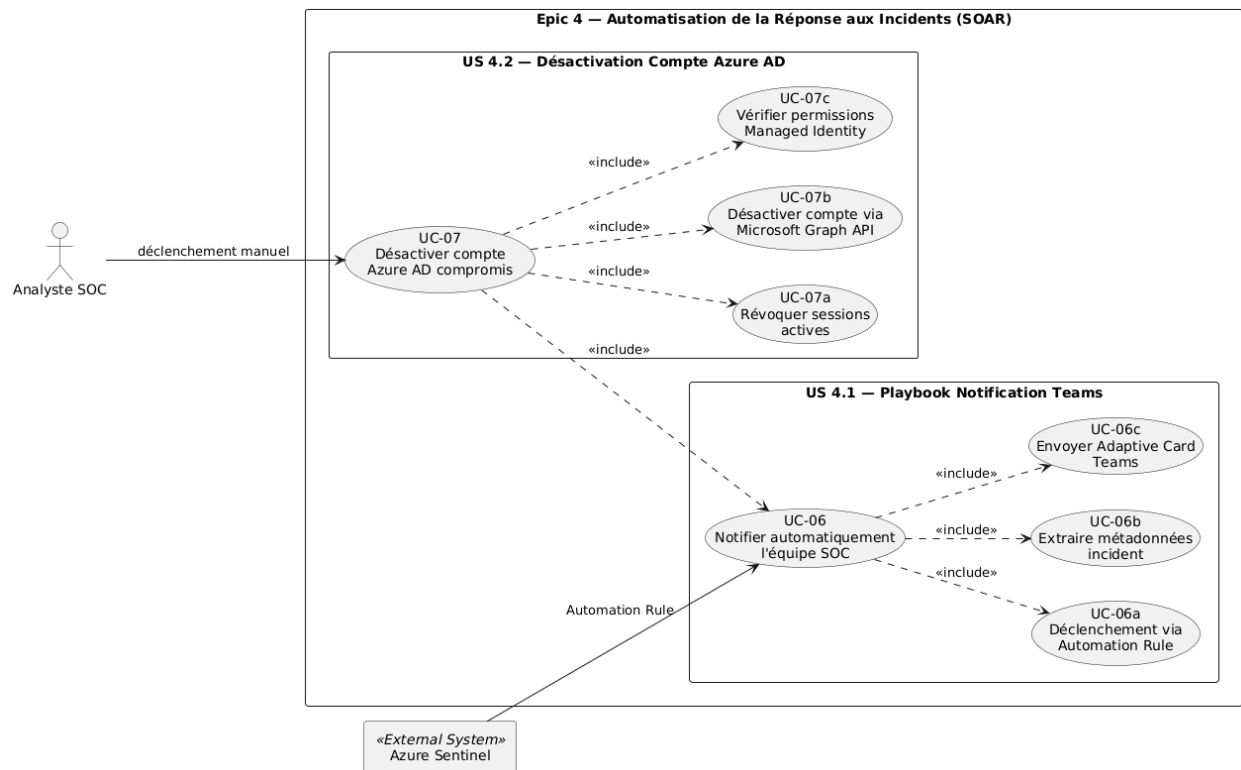


FIGURE 4 – UCd-04 — Use Case — Epic 4 : Automatisation SOAR

4.2 Diagrammes de classes

CLD-01 — Modèle de Domaine — Couche Infrastructure

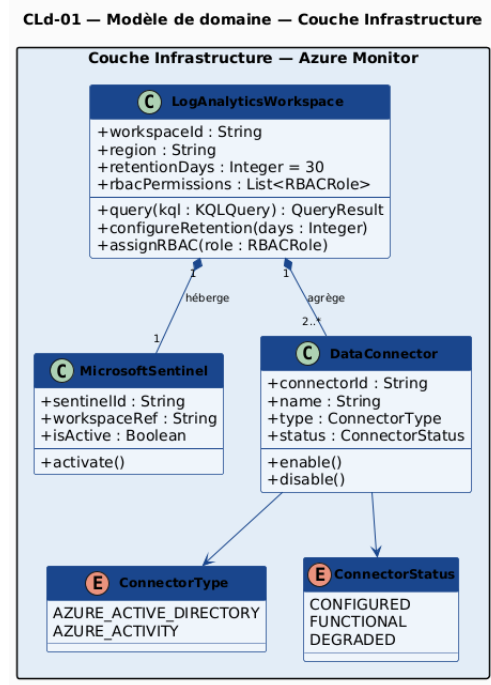


FIGURE 5 – CLD-01 — Modèle de Domaine — Couche Infrastructure

CLD-02 — Modèle de Domaine — Couche Détection

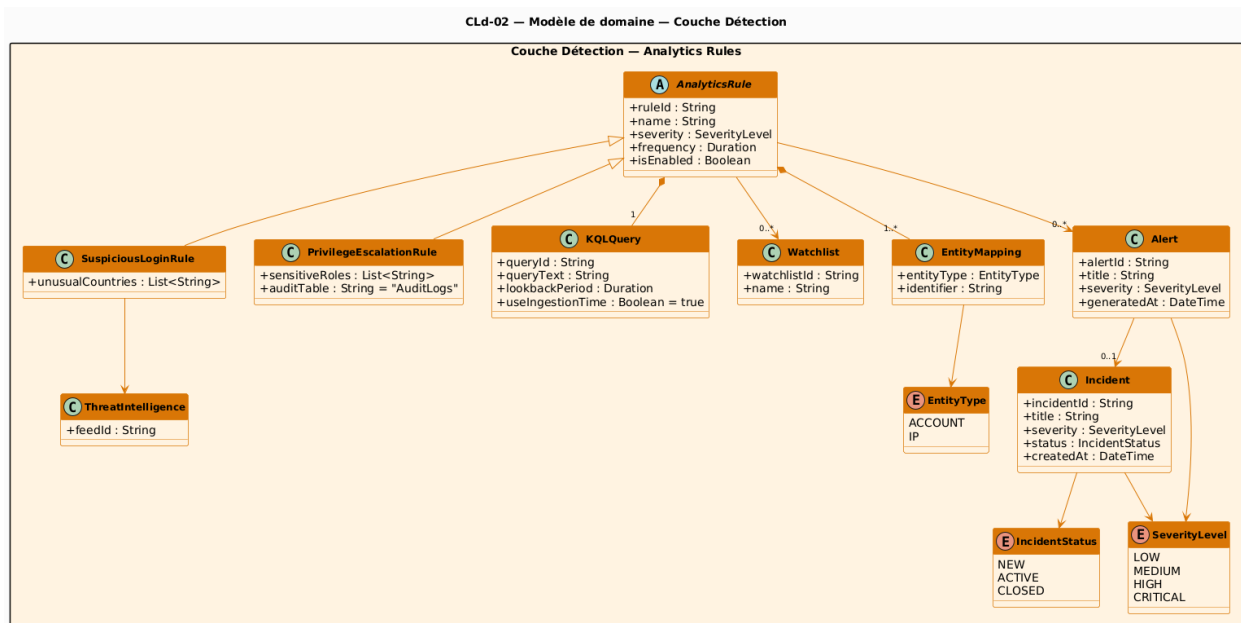


FIGURE 6 – CLD-02 — Modèle de Domaine — Couche Détection

CLD-03 — Modèle de Domaine — Couche Visualisation

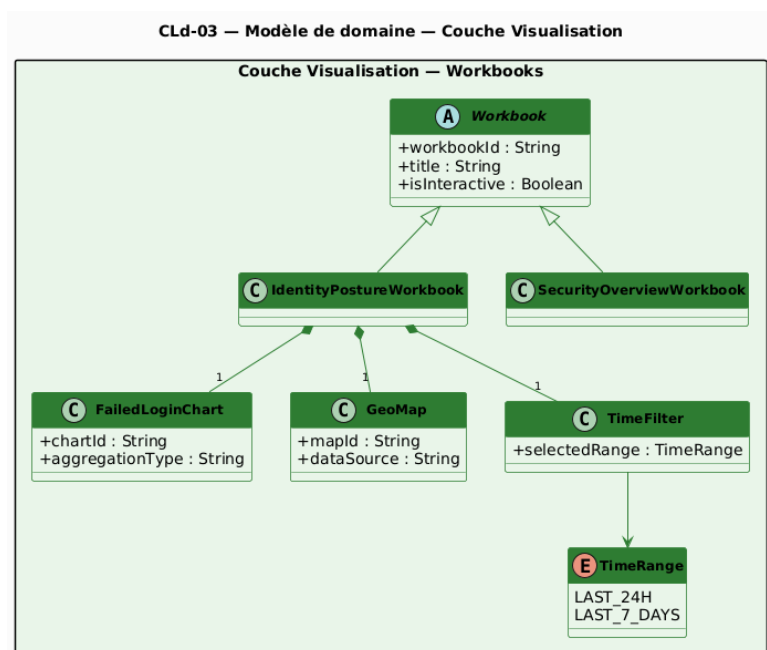


FIGURE 7 – CLD-03 — Modèle de Domaine — Couche Visualisation

CLD-04 — Modèle de Domaine — Couche Automatisation SOAR

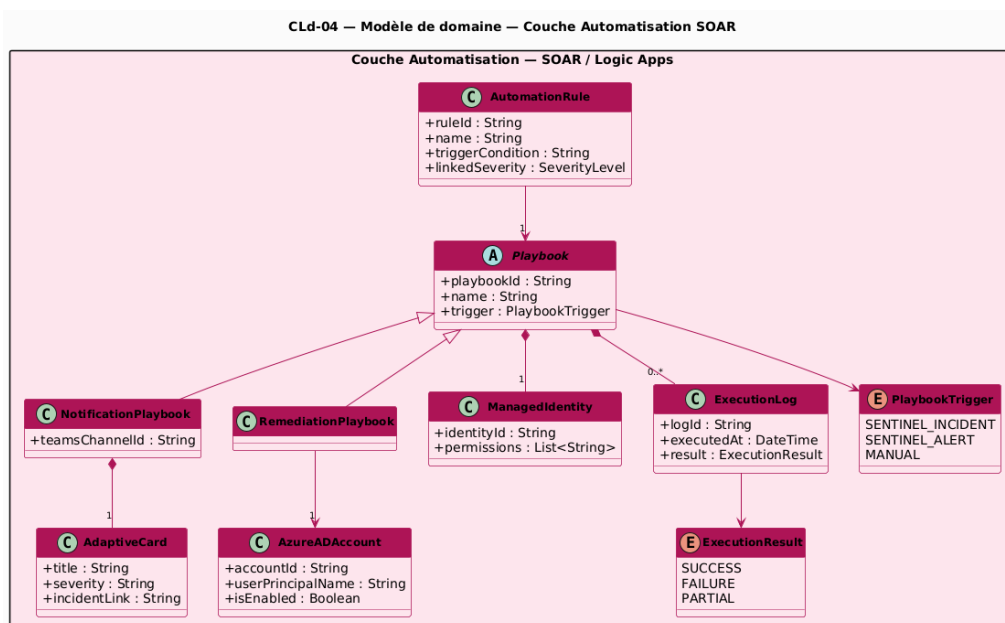


FIGURE 8 – CLD-04 — Modèle de Domaine — Couche Automatisation SOAR

4.3 Diagrammes de séquence

SEQ-01 — Séquence — Détection d'une connexion suspecte par IP malveillante

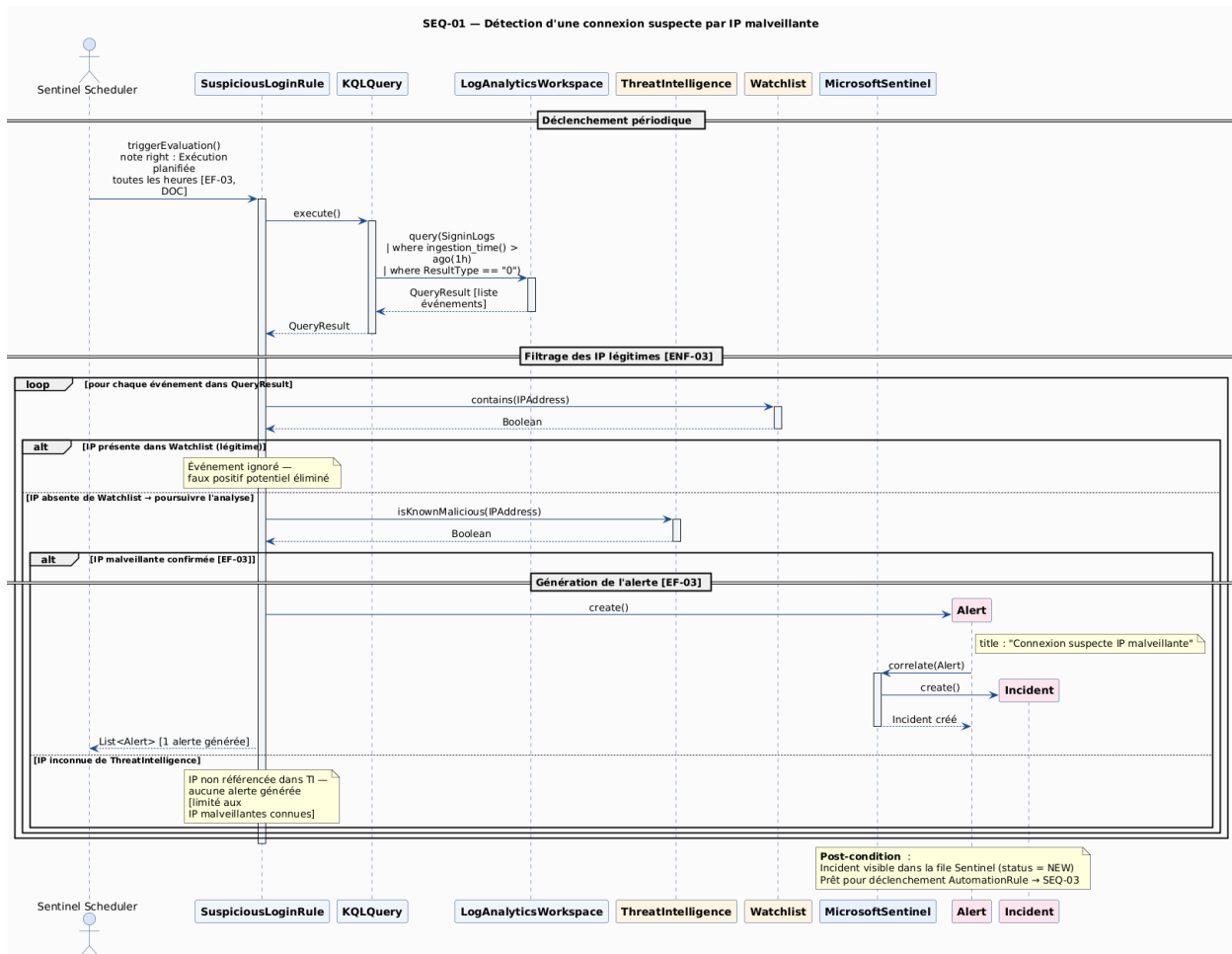


FIGURE 9 – SEQ-01 — Séquence — Détection d'une connexion suspecte par IP malveillante

SEQ-02 — Séquence — Détection d'une élévation de privilèges

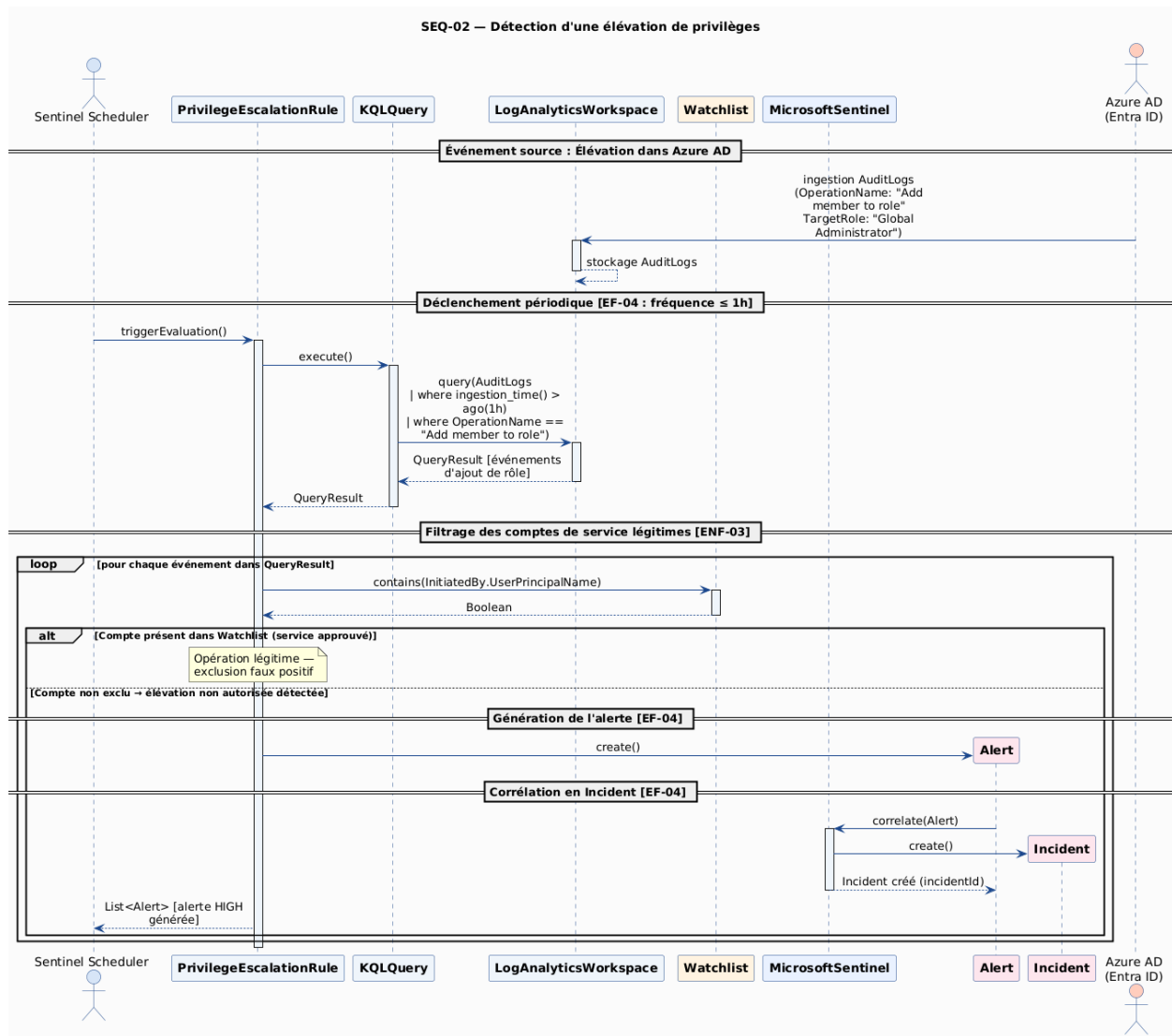


FIGURE 10 – SEQ-02 — Séquence — Détection d'une élévation de privilèges

SEQ-03 — Séquence — Notification automatique Teams (Playbook SOAR)

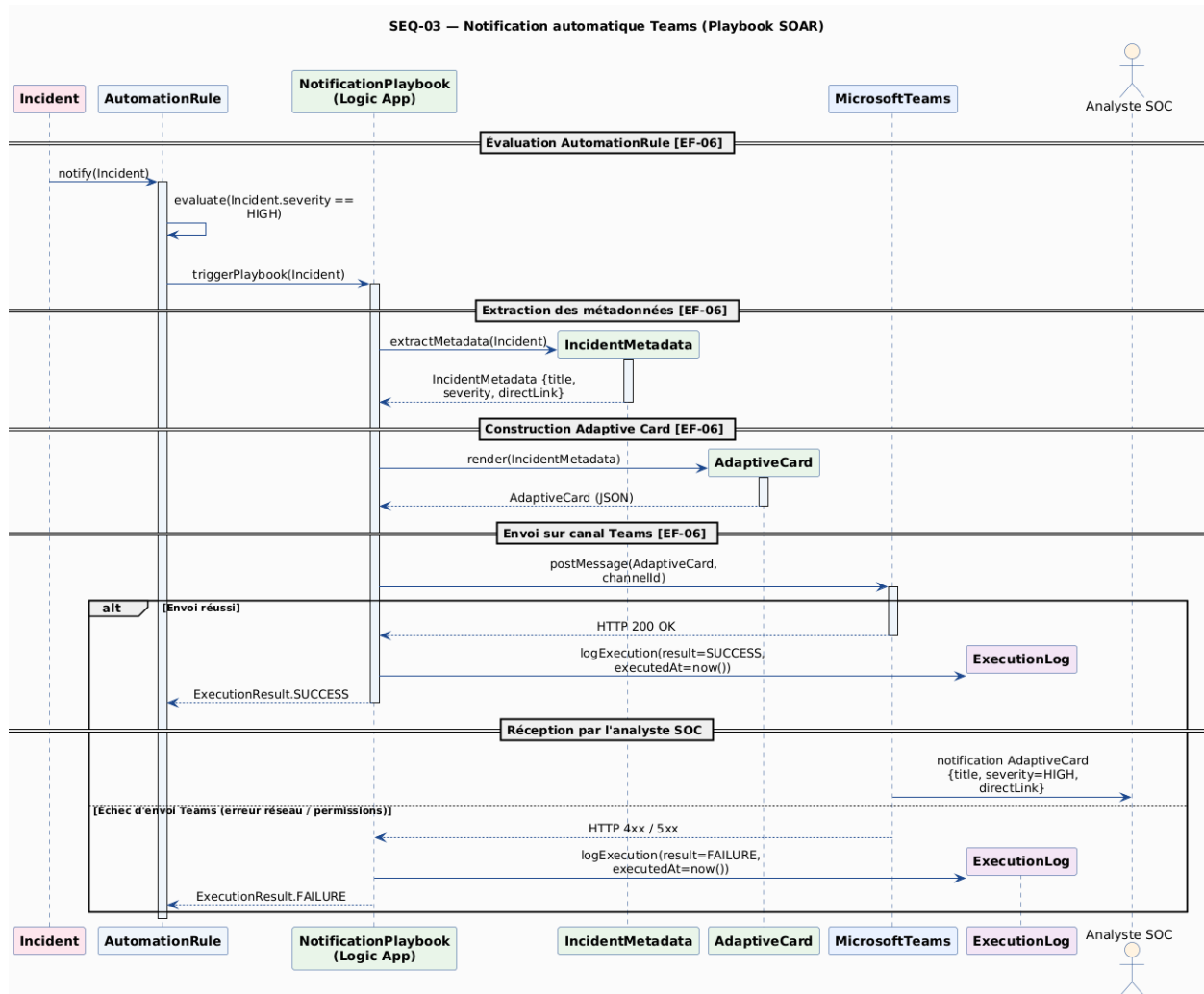


FIGURE 11 – SEQ-03 — Séquence — Notification automatique Teams (Playbook SOAR)

SEQ-04 — Séquence — Remédiation : désactivation compte compromis

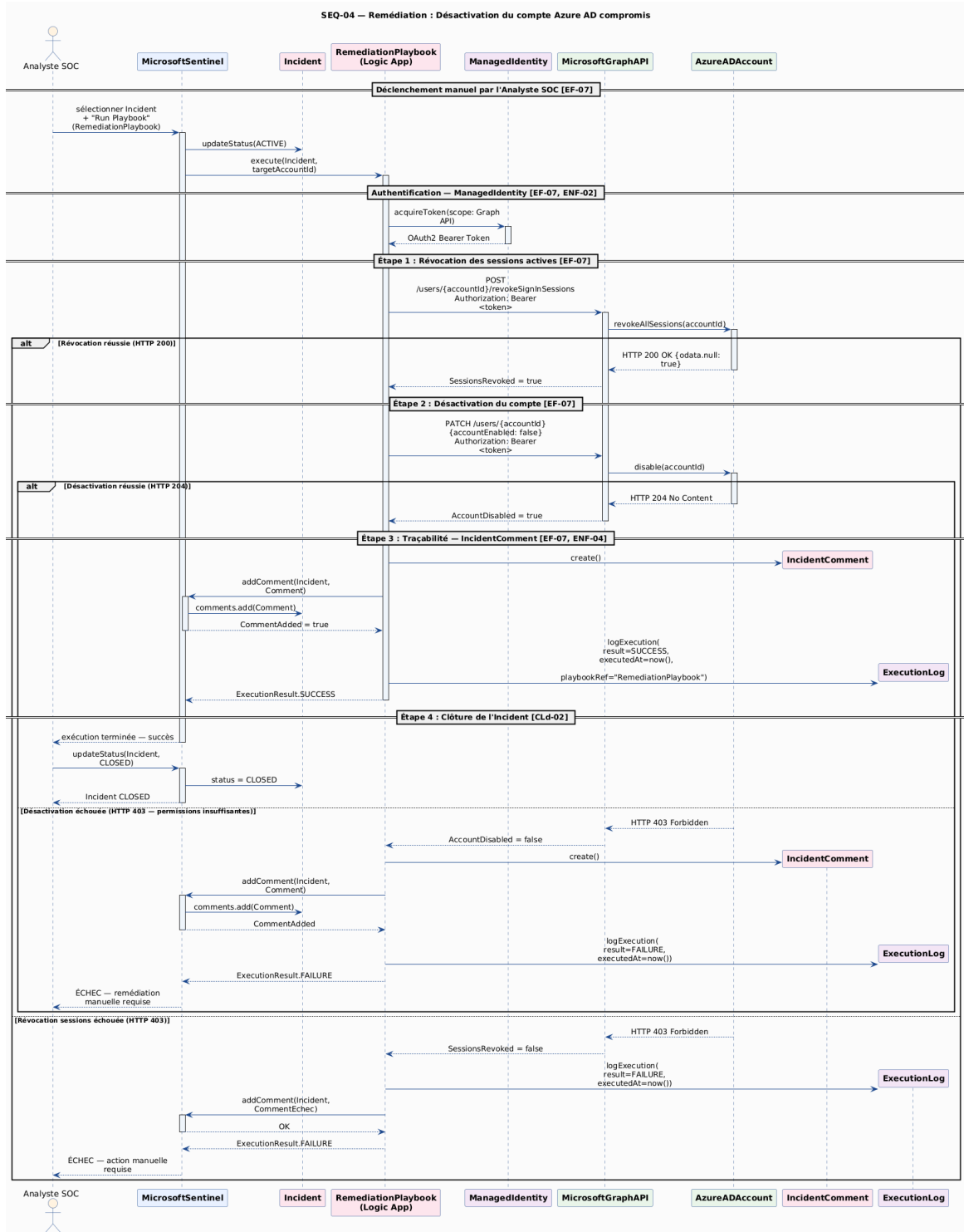


FIGURE 12 — SEQ-04 — Séquence — Remédiation : désactivation compte compromis

4.4 Diagramme de flux

WF-01 — Pipeline SIEM Cloud-Native : De la Collecte des Logs à la Remédiation Automatisée

4.5 Analyse des entrées et sorties du système

IO-01 — Architecture logique — Flux de données I/O du SIEM

IO-02 — Diagramme de composants / Architecture C4 Container

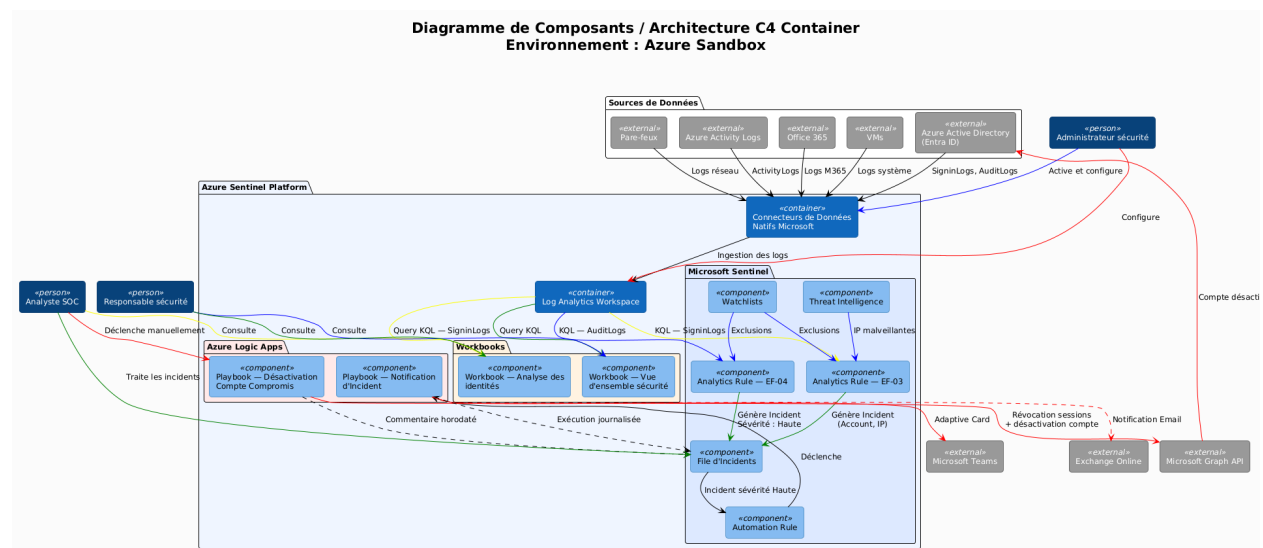


FIGURE 13 – IO-02 — Diagramme de composants / Architecture C4 Container

5 Architecture et choix technologiques

5.1 Vue d'ensemble de l'architecture

L'architecture retenue est intégralement cloud-native, déployée sur Microsoft Azure. Elle ne repose sur aucune infrastructure on-premise. Elle s'organise en quatre couches fonctionnelles distinctes et séquentielles : collecte, analyse et détection, visualisation, et remédiation automatisée.

5.2 Couches de l'architecture

Couche 1 — Collecte et ingestion des données

Composant principal : Azure Monitor / Log Analytics Workspace

Azure Monitor constitue le socle de collecte. Il agrège les logs et les métriques issus de l'ensemble des sources Azure. L'espace de travail Log Analytics est le point de centralisation unique de toutes les données ingérées.

Paramètre	Valeur retenue
Type	Log Analytics Workspace (Azure Monitor)
Rétention des données	30 jours (environnement de test)
Région	Région Azure du projet
Contrôle d'accès	RBAC restreint à l'équipe sécurité

Sources de données connectées (connecteurs natifs Microsoft)

Source	Connecteur Sentinel	Données ingérées
Azure Active Directory (Entra ID)	Azure Active Directory connector	SigninLogs, AuditLogs
Journal d'activité Azure	Azure Activity connector	Opérations sur les ressources Azure
Office 365	Office 365 connector	Activités Exchange, Share-Point
Machines virtuelles Azure	Azure Defender / MMA Agent	Événements systèmes, journaux sécurité
Pare-feux Azure	Azure Firewall connector	Logs réseau, flux bloqués

Remarque technique : le délai d'ingestion des logs Azure AD peut atteindre 15 à 30 minutes. Toutes les règles KQL doivent utiliser `ingestion_time()` en lieu et place de `Time-Generated` pour la fenêtre de recherche (lookback period), conformément au bug anticipé B-01 du cahier fonctionnel.

Couche 2 — Analyse et détection (SIEM)

Composant principal : Microsoft Sentinel

Microsoft Sentinel est activé sur l'espace de travail Log Analytics. Il assure la corrélation des événements, l'exécution des règles d'analyse, et la gestion du cycle de vie des incidents.

Moteur de détection — Analytics Rules (KQL)

Les règles d'analyse sont rédigées en Kusto Query Language (KQL). Le cahier fonctionnel définit un catalogue de 5 à 10 règles personnalisées. Les deux règles prioritaires sont :

Règle	Table KQL ciblée	Sévérité	Fréquence
EF-03 — Connexion depuis IP malveillante / pays inhabituel	SigninLogs + Threat Intelligence	Haute	Toutes les heures
EF-04 — Élévation de privilèges Azure AD	AuditLogs	Haute	Toutes les heures

Gestion des faux positifs — Watchlists

Des Watchlists Sentinel sont implémentées pour exclure des règles de détection les adresses IP et comptes de service approuvés, conformément au bug anticipé B-03. Les requêtes KQL intègrent une clause de filtrage référençant la Watchlist concernée.

Gestion des incidents

Tout déclenchement d'une Analytics Rule génère un incident dans la file d'incidents Sentinel. Les entités Account et IP sont mappées dans chaque alerte pour faciliter l'investigation par l'analyste SOC.

Couche 3 — Visualisation et reporting

Composant principal : Azure Sentinel Workbooks

Les Workbooks sont des tableaux de bord interactifs basés sur les données du Log Analytics Workspace. Deux Workbooks sont livrés dans le périmètre du projet :

Workbook	Contenu	Acteur
Vue d'ensemble de la sécurité	KPIs globaux, volume d'incidents, tendances	Responsable sécurité
Analyse des identités	Connexions échouées par raison, carte géographique des origines, filtres 24h / 7j	Analyste SOC, Responsable sécurité

Les Workbooks consomment directement les données Log Analytics via des requêtes KQL embarquées. Aucun outil de visualisation tiers n'est requis.

Couche 4 — Automatisation et remédiation (SOAR)

Composant principal : Azure Logic Apps

Azure Logic Apps est le moteur d'orchestration des Playbooks SOAR. Les Playbooks sont liés à Sentinel via des Automation Rules, qui définissent les conditions de déclenchement.

Playbook 1 — Notification d'incident (EF-06)

Attribut	Valeur
Déclencheur	Azure Sentinel Incident — sévérité Haute
Mode de déclenchement	Automatique (via Automation Rule)
Action	Post d'une Adaptive Card dans un canal Microsoft Teams
Données extraites	Titre de l'incident, sévérité, lien direct Sentinel
Traçabilité	Log d'exécution Logic App

Playbook 2 — Désactivation de compte compromis (EF-07)

Attribut	Valeur
Déclencheur	Azure Sentinel Alert ou Incident
Mode de déclenchement	Manuel (analyste SOC)
Actions séquentielles	1. Révocation des sessions actives Azure AD — 2. Désactivation du compte — 3. Ajout d'un commentaire dans l'incident Sentinel
Interface API	Microsoft Graph API (User.ReadWrite.All)
Identité d'exécution	Managed Identity de la Logic App
Traçabilité	Commentaire horodaté ajouté dans l'incident Sentinel

Remarque technique : la Managed Identity de la Logic App doit disposer de la permission User.ReadWrite.All sur Microsoft Graph. En cas d'absence de ce droit, le Playbook retourne une erreur 403 Forbidden, conformément au bug anticipé B-02.